

Entity-conditioned nulls for anomaly detection in authentication logs

Abstract

Anomaly detection on enterprise security telemetry is usually posed as outlier detection against a pooled population: a model is fitted to all accounts and an event is flagged when it lies far from that fit. We argue and then measure that this asks the wrong question. An account that is permanently unusual is not thereby suspicious, and an account that has changed is suspicious whether or not it is unusual for the organisation. We therefore condition each null on the entity that produced the event, so that the reference set for an authentication is that account's own history rather than the population's.

Evaluated on the Los Alamos National Laboratory authentication corpus, where 549 labelled red-team events occur among 4.19 million scored events, a per-entity novelty test attains a precision of 15.7% (95% CI 9.0–26.0) at 10 alerts per analyst-day against a base rate of 1.31×10^{-4} , a lift of about 1,200. A structural census locates the mechanism: the categories the per-entity tests express are enriched 139- and 184-fold among labelled events, while the category a population-rarity test expresses contains none of them. Two categories that entity-scope tests also express — off-hours activity and volume bursts — are not enriched at all, which accounts for those detectors' null results without appeal to misspecification.

We report three negative results of independent interest. Combining the detectors' p-values, by Fisher's method with Brown's correction or by the Šidák-corrected minimum, does not exceed the best single component at any budget. Alerting whenever any detector ranks an event highly is strictly dominated at equal cost and superior at equal depth, at 3.7 times the alert volume. And a population-scope model retains one capability the entity-scope framework lacks, so the two scopes are complementary rather than ordered.

Keywords: anomaly detection; multiple testing; conditional inference; false discovery rate; intrusion detection; decision theory.

1. Introduction

1.1 The operational problem

An enterprise authentication log records who authenticated to what, from where, and how. A single record from the corpus studied here carries nine fields: a timestamp, a source and destination account, a source and destination computer, an authentication type such as Kerberos or NTLM, a logon type such as Interactive or Network, an orientation, and whether the attempt succeeded. A field with no interpretable value is written as a literal `?`, which is a distinct state from absence and is treated as one throughout.

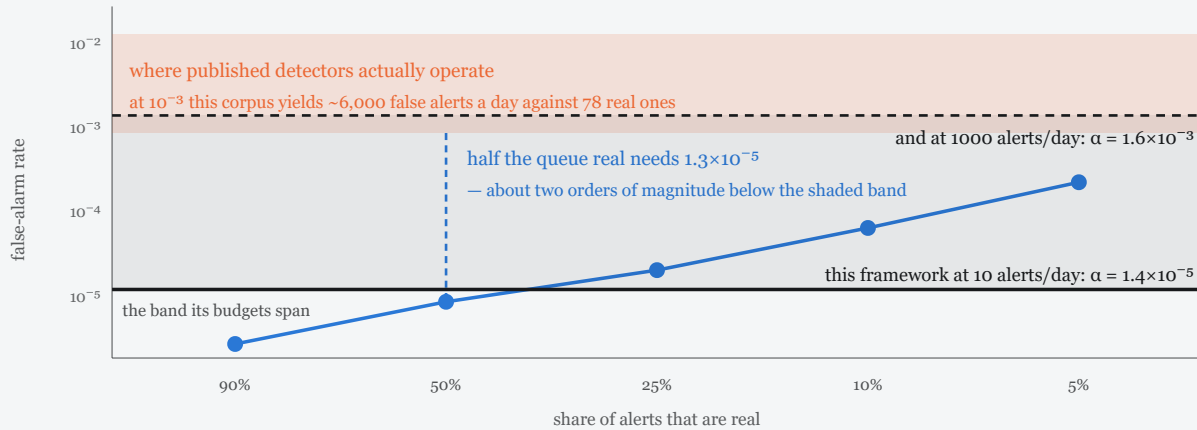
Two features of this setting determine what any statistical method can achieve on it.

The first is volume against rarity. A mid-sized organisation generates tens of millions of authentications a day as ordinary business: service tickets, screen unlocks, share mounts, scheduled jobs. An intrusion touches tens of events. On the corpus used here, 42.2 million events were scored over seven days and 549 of them are labelled, a base rate of 1.30×10^{-5} . Writing π for that rate and α for a per-event false-alarm rate, the share of alerts that are real is

$$P(\text{intrusion} \mid \text{alarm}) = \pi / (\pi + (1 - \pi) \cdot \alpha),$$

so half a queue is real only at $\alpha \approx 1.3 \times 10^{-5}$, or about 78 false alerts a day. At $\alpha = 10^{-3}$, an operating point typical of published detectors, the same corpus yields approximately 6,000 false alerts a day against 78 real ones. This is Axelsson's base-rate argument [1] applied to our own data, and its usual consequence is that the binding constraint is the suppression of false alarms rather than the recognition of intrusions.

false-alarm rate needed for a given share of alerts to be real, at this corpus's base rate



The base rate, not the model, sets the ceiling. Over the scored window this corpus carries 549 labelled events among 42,218,530 — one in 76,901. Inverting the arithmetic for a desired precision gives the false-alarm rate a detector would have to achieve, and it lands two to three orders of magnitude below where published detectors operate. Two consequences follow: "everything suspicious and nothing else" is not attainable here by any known method, and even a perfect detector still yields 87 alerts a day, because 78 genuinely suspicious events happen daily. What an operator can choose is the error rate; the volume follows from it.

The two horizontal rules mark where this framework actually operates, measured on the `r11` subset, and the band between them is what its alert budget spans. At 10 alerts a day its false-alarm rate is $\alpha = 1.4 \times 10^{-5}$ — the order the arithmetic asks for, and two orders of magnitude below where published detectors sit. At 1000 a day it is 1.6×10^{-3} , inside the shaded band.

The rules are deliberately not points on the curve. The curve inverts the identity for a detector that misses nothing; this one misses most, with recall of 2.0% at the tighter operating point, and its queue is 15.7% real rather than the large majority that perfect recall at that rate would give. The reading is therefore the opposite of the usual one: suppressing false alarms to the rate the base rate demands is not this framework's binding constraint, because it already achieves it. Recall is.

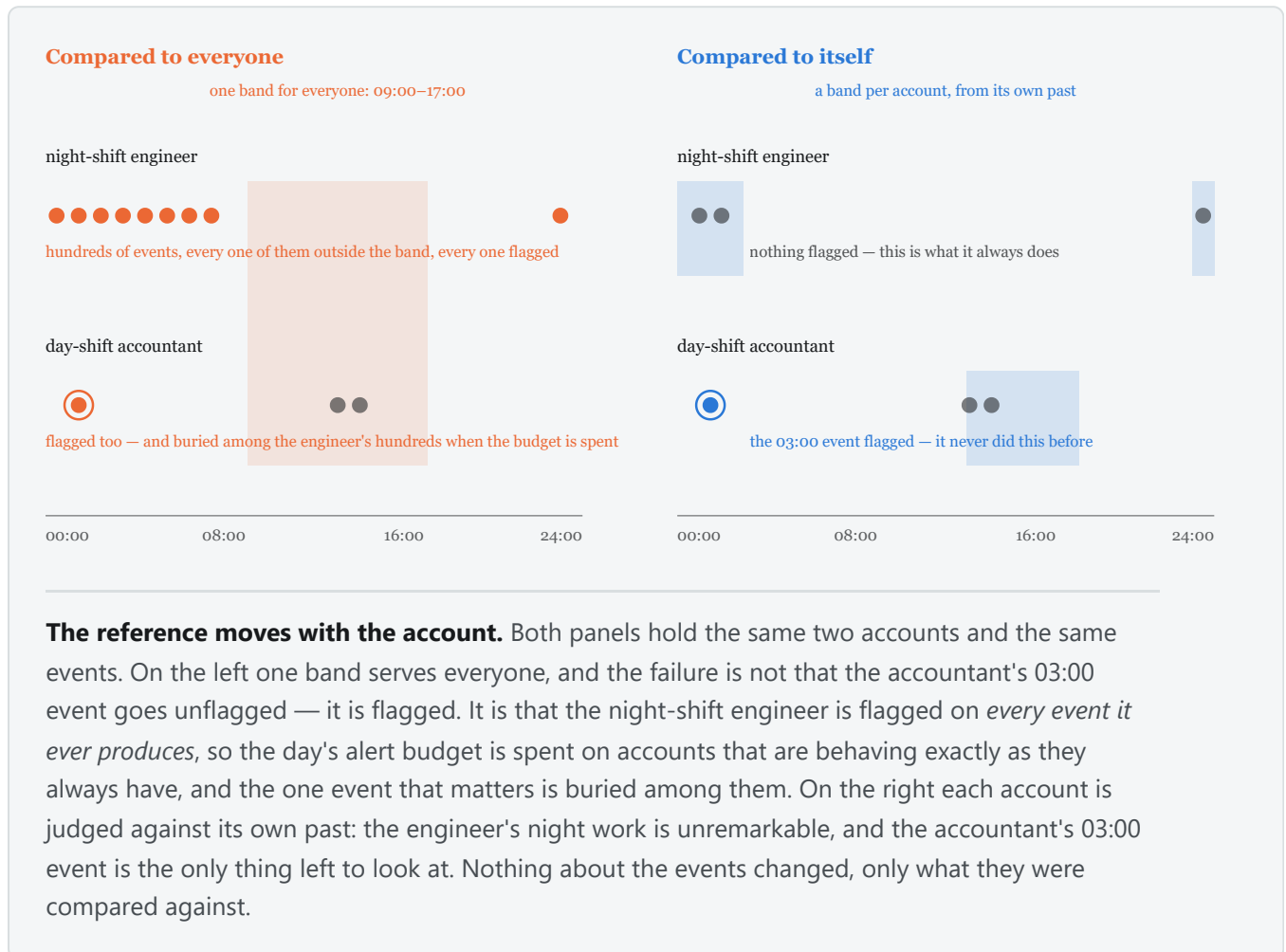
The figure inverts that identity for a detector which misses nothing, and marks where this framework's own operating points fall. Both lie well below where published detectors operate — one of them by two orders of magnitude — and both lie far from the curve, because the framework's recall is 2.0% to 36.6% rather than 1. The consequence is worth stating at the outset, because it inverts the usual reading: suppressing false alarms to the rate the base rate demands is not this framework's binding constraint, since it already achieves that rate. Recall is.

The second is that the consumer of the output is a person with a fixed working day. A security operations centre triages a bounded number of alerts per shift because each costs a human minutes to hours. That bound is a staffing constant, not a tuning parameter, which is why every comparison in this paper is made at a matched

number of alerts per analyst-day rather than at a matched threshold: two methods thresholded alike may emit volumes differing by three orders of magnitude, and the comparison would then be between their volumes.

The labels deserve a third remark, because they shape every figure. A red team is an authorised offensive exercise conducted by people who record what they did. The label file is that record: it is not an exhaustive annotation of the log. Two consequences follow and are carried throughout. Genuine malicious activity that the red team did not record, or that was not theirs, is counted as a false positive, so every precision figure in this paper is a lower bound. And the recall denominator is what was written down rather than what happened.

1.2 Why a population-scope null asks the wrong question



Consider a systems administrator who works nights and authenticates to database servers no one else touches. A model fitted to the population places her far from its centre on every event she generates. She is a persistent outlier and she is not an intruder. Conversely, an account whose behaviour has just changed completely may still sit inside the population's bulk, because the values it has moved onto are ordinary for other people.

Both errors have the same cause: the question "is this event unusual for this organisation" is not the question an analyst needs answered, which is "has this account departed from its own behaviour". Formally, the two differ in the reference set against which an observation is judged exchangeable — the population of all accounts, or the history of one. Conditioning on the entity is the whole of the commitment this paper makes, and section 5.1 shows it is where the discriminating information on this corpus lies.

The distinction is not merely conceptual. It also determines what a fixed budget buys: a population-scope model spends its budget on whichever accounts are furthest from the mean, and those accounts are the same ones every day.

1.3 Contributions, and what is not claimed

We contribute: a family of entity-conditioned nulls over heterogeneous log fields that requires no advance declaration of a field's type, cardinality or value set (section 3.2); a measurement of what per-entity conditioning is worth at matched analyst-day budgets, with intervals (section 5.2); a structural census that identifies which properties of an event carry the discriminating information, and which do not (section 5.1); and per-mechanism sensitivity against a corpus of planted attacks designed to hold population rarity out (section 5.3).

We do not claim state-of-the-art detection. Precision reaches 15.7% at the tightest budget studied, which is good against a base rate of 1.31×10^{-4} and not good enough to act on unattended. We do not claim that combining evidence across detectors helps: three combination rules are measured and none exceeds its own best component at equal cost (section 5.4). We do not claim that population-scope conditioning is useless; it retains one capability this framework lacks (section 5.7). And we do not claim generalisation beyond authentication telemetry of this shape, nor to the full population: the figures below are measured on entity subsets, for reasons section 2.2 states.

The framework is stated as six requirements, referred to throughout by number.

REQUIREMENT	
R1	A verdict is a function of the event and of persisted state only, so scoring is reproducible from the record and independent of batching.
R2	No component requires advance knowledge of a field's type, cardinality or value set. One field must be declared to be the entity, and one the timestamp; nothing else.
R3	Abstention is an outcome. A component with no basis for an opinion says so, and does not contribute a neutral value.
R4	Scoring is deterministic: no wall clock, no randomness, and a canonical total order before every floating-point reduction.
R5	A verdict carries the evidence needed to reconstruct it.
R6	Alert volume follows from a stated exchange rate between a missed intrusion and a wasted investigation, not from a quota.

2. Data and evaluation design

2.1 Authentication telemetry and its labels

We use the Los Alamos National Laboratory comprehensive cyber-security events data set [2], released CCo, and specifically its authentication log: 1.05 billion events over 58 days from 12,425 users and 17,684 computers, with a labelled red-team exercise embedded in it.

The unit of analysis is a human account. Machine accounts, which the corpus writes with a trailing `$`, together with `SYSTEM` and `ANONYMOUS LOGON`, are excluded: they are not individuals, and an ethogram of an individual is what this framework builds. The restriction costs no labels, because all 104 accounts the red team touched are human accounts.

The label file carries 749 rows, of which 715 are distinct — 34 are exact duplicates — naming 104 accounts. Its structure is highly concentrated: 93.6% of rows share a single source computer, and two of the seven scored days carry 482 of the 700 post-boundary labels. The effective sample size is therefore far below 549, a point section 6.2 returns to.

Two properties of the corpus bear on specific detectors. Distinct human-user counts follow a weekly cycle, roughly 12,800 on weekdays against 5,400 at weekends, with daily volume between 13.1 and 25.0 million events; a null over an account's hour-of-day or event count must absorb that. And failed authentications appear in the corpus only for accounts that succeeded somewhere in the data set, so the failure population is conditioned on eventual success. That is a property of the archive and not of a live stream, and the success field is one the detectors score, so it is a genuine selection artefact; we report it here and revisit it in section 6.2.

2.2 Windows, entity population and sampling

The first seven days ($t < 604,800$ s) are a burn-in window: events are scored, so that state warms under exactly the code path that scoring uses, but nothing is emitted, counted or alerted on. Two quantities are fitted on this window and frozen at its boundary — a between-detector covariance and a conformal calibration (section 3.3) — and nothing fitted there is ever updated by an event it is later used to score.

The window was chosen before any end-to-end measurement was taken and is recorded in the run metadata by the commit that fixed it. It costs the 49 labelled events that fall inside it, on days 1, 2, 5 and 6. We note the provenance because it is the paper's defence against the charge that the split was chosen after seeing results: it was not, and the record shows it.

The scoring window is $t \in [604,800, 1,209,600)$ s: seven days, days 7 to 13 inclusive.

Four sampling designs appear below. Three are entity samples, taken because a fixed alerts-per-day budget is a far harder target on 42.2 million events than on 4.2 million, and because a population-scope quantity computed on a sample is a statement about the retained accounts. Every labelled account is retained in every sample, which inflates the labelled share and is why each design's base rate is stated rather than assumed.

DESIGN	SELECTOR	SCORED EVENTS	LABELLED	BASE RATE
full	none	42,218,530	549	1.30×10^{-5}
r11	1 entity in 16, residue 11	4,190,603	549	1.31×10^{-4}
inj	1 entity in 16, residue 7, plus planted attacks	4,494,396	1,405	3.13×10^{-4}
holdout-r7	days 7–8 of the residue-7 corpus	1,427,225	262	1.84×10^{-4}

Because labelled accounts are exempt from sampling, the residue-7 and residue-11 corpora share their labelled events and differ only in background and window. A result reproduced across them is therefore a check on sensitivity to the background population, and not an independent replication; we describe it as the former.

2.3 Planted attack mechanisms

The real campaign supplies one uneven mixture of mechanisms, which cannot separate "this detector cannot express this mechanism" from "this corpus barely contains it". We therefore plant synthetic attacks of six named kinds into a held-out copy of the corpus, eight victim accounts per kind, entirely inside the scoring window. Victims are disjoint from every account the real labels name, so the account alone determines which ground truth an event belongs to.

Each kind isolates one premise. **Credential spray** sends an account to many destinations it has never used inside ten minutes. **Lateral movement** walks a connected path of hops, each sourced from the previous hop's destination, so that every computer is real and only the pairings are new — a mechanism no test scoring fields independently can express. **Off-hours access** uses only values the account already uses, twelve hours from its own established window. **Privilege escalation** introduces an authentication type absent from the account's history at its usual hour and host. **Low-and-slow** exfiltration uses familiar values only, with a modest sustained volume increase. **Account takeover** changes destination, authentication type, logon type and hour at once, as an upper bound.

The design decision that matters statistically is the choice of planted values. A planted value is the *most population-common value the victim has never used*. Sampling the vocabulary uniformly instead plants values that are rare population-wide, and then a population-rarity test detects the planted attacks for the wrong reason; that error was made in an earlier version of this corpus and is visible in its measurements. Choosing the most ordinary unused value tests per-entity novelty with population rarity held out, which is the only construction under which the per-mechanism table separates the two questions this paper is about.

Section 5.3 reports where that construction succeeds and where it cannot, which depends on the cardinality of the field being substituted.

Two limits on how a per-mechanism rate may be read. Value choice is deterministic given the corpus, so every victim of a kind receives the same planted values: the events of one kind are not independent draws and the effective sample size is nearer the eight victims than the event count. And sensitivity against planted labels is a claim about whether a test responds to a mechanism, not about detecting an intrusion. The two ground truths are reported side by side throughout and are never summed.

3. Method

3.1 The entity-conditioned null

Write an event as a set of field–value pairs together with an entity e and a time t . For each field the framework maintains a per-entity summary of that entity's history, decayed exponentially in event time with a half-life of seven days, and asks a question of the form

H_0 : this observation is exchangeable with e 's own decayed history for this field.

Six such questions are asked, each returning a p-value under its own null, or abstaining. Nothing about the construction is specific to authentication; what makes a question available is the inferred kind of the field, not its name.

Novelty asks whether e has taken this categorical value before. The predictive is Dirichlet–multinomial with concentration a over the decayed counts, so a value seen n_v times out of n receives roughly $(n_v + a)/(n + a(K+1))$ and a first-ever value receives the reserved mass $a/(n + a(K+1))$. With $a = 1$ and $n \gg K$ that reserved mass is approximately $1/n$, which is the detector's most important property and its principal weakness: **the p-value for a first-ever value is set by the length of the account's history rather than by how surprising the value is**, so a quiet account cannot produce an extreme p-value however anomalous its behaviour. Section 6 returns to this.

Novelty rate exists because of that weakness and asks a scale-free question instead: is e producing first-ever values faster than it historically does? Over an hourly window of m events, the count K of first-ever values is referred to a Beta-binomial predictive, $K \sim \text{BetaBinomial}(m, a, b)$, where the Beta carries the posterior over e 's own rate of producing novelty. Carrying that posterior rather than a point estimate is what stops a second novel value from an account with twenty events of history being called overwhelming.

Timing asks whether the hour is unusual for e , estimating e 's time-of-day density on the 24-hour circle by von Mises kernel density estimation, maintained as a truncated Fourier series whose harmonic weights $r_h = I_h(\kappa)/I_0(\kappa)$ are the kernel's own Fourier coefficients. The concentration κ follows from a bandwidth stated in hours, here 1.5.

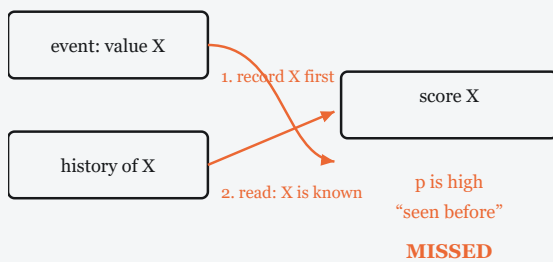
Volume asks whether e 's activity in the current period is unusual for e , referring the period's event count to a Gamma–Poisson predictive fitted on e 's completed periods. The predictive is deliberately over-dispersed relative to the Poisson, which is what makes it tolerant of ordinary bursts and, as section 5.3 shows, blind to sustained small increases.

Pairing asks whether e has combined two values before. A pair is addressed as a value of a synthetic composite field, so novelty's estimator scores it unchanged; the question is per-entity, not population.

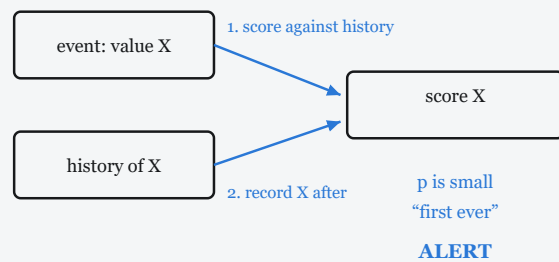
Marginal is the one population-scope question retained: is this value rare across the whole population, under decayed population counts with the same Dirichlet form? It is present because a comparison needs it, and because — as section 5.3 shows — it turns out to detect something the entity-scope questions do not.

Each detector may score several fields of one event; the arm for that detector takes the most extreme, and where the detector combines fields internally it applies a Šidák correction for the number tested.

Observe, then score



Score, then observe

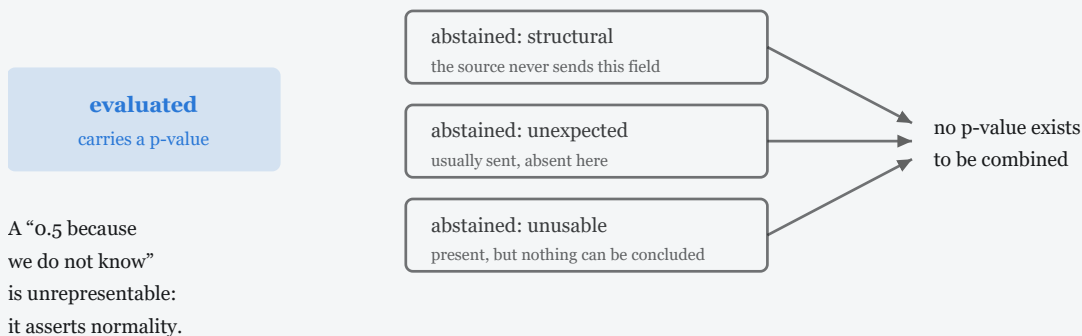


Both arrangements return a number. Only one of them is measuring anything.

The failure is silent, which is what makes it dangerous. Update state before scoring and a first-ever value is already a known value by the time it is judged, so novelty detection dies while still emitting plausible p-values. Nothing in the output announces it. The framework therefore makes the ordering unexpressible rather than conventional: `score` holds no means of writing, and the update it computes does not exist until it has produced it.

Ordering is fixed and is the framework's leakage control: every detector scores against pre-event state, the combination is computed, and only then are observations committed and the field registry updated. A first-ever value is therefore still novel at the moment it is scored. The same rule applies at the window level, and it cuts the other way too: because an event updates *e*'s state after being scored, a sustained intrusion progressively enlarges its own reference set. Section 6 treats this as a live threat rather than a solved problem.

3.2 Inferring what a field is, and declining to answer



Declining is not the same as reporting nothing unusual. A verdict has four states and only one of them carries a p-value, so a detector with no basis for an opinion cannot express a confident middle value — the field is unreachable. An abstention reduces the degrees of freedom of the combination rather than contributing to it. This is what lets the system degrade honestly instead of inventing findings when a source changes shape.

R2 requires that no component be told a field's type, cardinality or value set. A registry observes values as they arrive and settles each field into one of five kinds — categorical, boolean, discrete, continuous, identifier — after which the detectors iterate the registry rather than a list of field names. Onboarding a new log source is therefore configuration rather than code, and the one thing that must be declared is which field carries the entity.

The identifier kind carries the weight here. A field whose values are almost all distinct — a session GUID, a request id — is unbounded by construction: every value is a first-ever value, so a novelty test on it fires on every event and, being the most extreme thing in the queue, consumes the entire budget. The registry classifies such a field as an identifier and detectors decline it. That is not a heuristic convenience; without it the framework's headline arm is a random-number generator with a large p-value.

R3 makes abstention an outcome rather than a neutral score. A detector with no basis for an opinion — the field is absent, or present but not interpretable, or the entity has no history for it — says so, and the abstention reduces the number of tests combined rather than contributing a p-value of one. The distinction matters at this base rate: a neutral value entered into a combination over six tests is not neutral, it is evidence of ordinariness, and in Fisher's sum five such values will bury one informative test.

Values are handled as text and each inferred kind supplies its own scoring representation, so no field is cast to a numeric type on the strength of the first values seen.

3.3 Combination, calibration and allocation

Given J evaluated p-values for one event, four rules for turning them into one decision are measured. All four are defined here so that section 5.4 can report outcomes without defining machinery.

The composite is Fisher's method [3], $X^2 = -2 \sum \ln P_j$, referred to $\chi^2(2J)$, with Brown's correction [4] for dependence between the detectors: the burn-in covariance of the $-2 \ln P_j$ supplies a scale c and effective degrees of freedom f , and X^2/c is referred to $\chi^2(f)$.

Brown's correction requires a positive variance estimate for X^2 , and on this corpus it does not always get one. With six detectors the burn-in covariance implies $\text{Var}[X^2] = -27.5$, which no joint distribution of the statistics can produce. When that happens the correction is not applied and the combination degrades to plain Fisher, and the run records that it did. The degradation is the specified behaviour rather than a repair invented for this paper, and it matters that it is stated: every composite figure below is Fisher's statistic without Brown's correction. The negative estimate is itself informative, and section 6 reads it.

The corrected minimum takes the smallest p-value and corrects it for multiplicity by Šidák [5]: $P = 1 - (1 - \min_j P_j)^J$. It asks whether *any* detector found the entity out of character, which is closer to the question the framework poses than whether the evidence is jointly unusual.

The union asks the same question with the p-value scale removed. Each detector ranks the day on its own p-value, an event takes the best rank it attains in any detector, the union is deduplicated on event identity, and ties break on that identity rather than on a p-value — rank collisions are structural, since every detector has a rank 1, and breaking them on $\log P$ would hand each collision to whichever detector's numbers happen to be smallest. It is charged two ways: **at equal cost**, truncated to the same alerts a day every other arm gets, and **at equal depth**, every detector keeping its own top B with the deduplicated union emitted whole. A fused rank is not calibrated against any of these nulls and carries no tail-probability interpretation; it reports a selection, and each alert still carries the p-value of the detector that raised it.

Conformal calibration [6] is applied optionally and orthogonally to all of the above. It replaces each detector's model tail with that value's rank in the same detector's burn-in distribution, which is super-uniform whether or not the model is correct. It cannot change any single detector's own ordering, a rank transform being monotone, so per-detector figures are identical with and without it; what it changes is which detector supplies the minimum, and what a combination is summing. It also floors every p-value at $1/(n+1)$, so events more extreme than the whole burn-in sample tie there, and the model log p-value is retained as the tie-break.

4. The decision problem

R6 states that alert volume follows from a stated exchange rate rather than from a quota, and the reason is a pathology of quotas: a system tuned to emit 100 alerts a day emits 100 on a quiet day too, all of them benign. If nothing happened, the right number of alerts is zero.

We therefore score an alerting configuration by

$$U = v \cdot TP - c \cdot FP,$$

where v is what catching one incident is worth and c what one wasted investigation costs. Only the ratio v/c is identifiable from counts, so an operator supplies one number. A queue is worth reading exactly when $TP/FP > c/v$, so a target true-to-false ratio is the exchange rate; but utility also says how many rows to take, which a ratio cannot.

Maximising a ratio does not work here, and the reason is worth stating because the failure is structural rather than a matter of tuning. TP/FP is precision under the monotone transform $P/(1-P)$, so maximising it maximises precision, whose maximiser is the smallest queue containing a true positive. Forbidding $TP = 0$ moves that corner from "alert on nothing" to "alert on one thing" rather than removing it. Any objective that is a function of precision alone is scale-free, and a scale-free quantity cannot say how many rows to show; the objective must contain a term that grows with true positives found. The same argument disposes of accuracy, balanced accuracy, F1 and Youden's J as objectives at this base rate: each is a fixed and unstated exchange rate wearing a metric's clothes. Accuracy is the sharpest case — over the scored window, alerting on nothing scores 99.9987%.

A budget is therefore a **ceiling rather than a quota**: within it, the queue is truncated where marginal alerts stop paying. Section 5.5 measures what that truncation costs and buys, at an exchange rate of $v/c = 10$ stated in advance.

5. Results

All comparisons are at matched alerts per analyst-day. Counts of alerts are over the whole seven-day window, so a budget of B corresponds to $7B$ alerts.

5.1 What distinguishes the campaign

Before any detector, it is worth asking what property of a labelled event a method could exploit. We therefore census five structural properties of an event relative to the history it was scored against. The properties are defined by facts about the event and the history — has this entity taken this value before, had this pair occurred before, is this hour improbable for this entity — and never by which detector produced the smallest p-value: a partition defined by our own detectors would flatter the framework by construction.

On `r11`, over 4,190,603 scored events of which 549 are labelled:

PROPERTY	LABELLED	SHARE OF LABELLED	BACKGROUND	SHARE OF BACKGROUND	LIFT
novel pairing for this entity	362	65.9%	19,841	0.473%	139
novel value for this entity	215	39.2%	8,913	0.213%	184
volume burst for this entity	199	36.2%	1,143,820	27.3%	1.3
outside this entity's hours	181	33.0%	1,576,171	37.6%	0.9
population-rare value	0	0.0%	4,835	0.115%	0.0

The properties are not mutually exclusive and 92 labelled events exhibit none of them.

Three readings, and they set up everything that follows.

The two per-entity novelty properties are enriched by factors of 139 and 184. That is where the discriminating information on this corpus is, and it is the empirical content of the claim section 1.2 makes on general grounds.

Population rarity is not merely weaker; it is **empty**. Not one of the 549 labelled events holds a value rare in the population, while 4,835 background events do. A test of population rarity on this campaign is therefore not a worse test of the same thing — it is a test of something the campaign does not exhibit. This is the strongest form the paper's central claim takes, and it is a statement about this campaign rather than about population-scope methods in general; section 5.3 shows the same property behaving differently on planted attacks.

The remaining two properties are **not enriched at all**: 1.3 and 0.9. Volume bursts and out-of-hours activity are as common among background events as among labelled ones. This is the explanation for the null results the timing and volume detectors return throughout section 5.2, and it is a better explanation than misspecification: a test of a property that does not separate labelled events from background cannot rank labelled events highly however well it is specified. It also bounds what any amount of work on those two detectors could recover here.

5.2 Detection on the real campaign

lanl-r11-b1000-union-d7-14-002 and analysis-r11-b1000-conf-001, 549 labelled events among 4,190,603 scored. Every proportion carries a 95% Wilson interval [7], and section 6.2 states why those intervals are optimistic.

ARM	10/DAY	100/DAY	1000/DAY	PRECISION AT 10/DAY	RECALL AT 1000/DAY
novelty	11	60	201	15.7% (9.0–26.0)	36.6% (32.7–40.7)
pairing	4	59	127	5.7% (2.2–13.8)	23.1% (19.8–26.8)
novelty rate	0	22	185	—	34.9% (31.0–39.1)
timing	0	0	6	—	1.1% (0.5–2.4)
volume	0	0	0	—	0.0% (0.0–0.7)
marginal	0	0	0	—	0.0% (0.0–0.7)
corrected minimum	4	47	161	5.7% (2.2–13.8)	29.3% (25.7–33.3)
composite	0	6	113	—	20.6% (17.4–24.2)

Four readings.

The per-entity novelty tests carry the campaign and the population test does not. At the tightest budget the novelty detector returns 11 true positives in 70 alerts: a precision of 15.7% (9.0–26.0) against a base rate of 1.31×10^{-4} , a lift of about 1,200. Precision falls to 2.9% at 1000 alerts a day while recall rises to 36.6%, which is the ordinary consequence of taking a longer prefix of one ranking rather than evidence about the ranking's quality.

Two arms are not distinguishable and should not be ranked. At 100 alerts a day the novelty detector catches 60 and the pairing detector 59, with recall intervals of 10.9% (8.6–13.8) and 10.7% (8.4–13.6). Those are the same measurement. The two questions are also nearly the same question — a novel pairing is a novel value of a composite field — and section 5.4 shows their detections overlap heavily.

The volume and marginal arms detect nothing at any budget, and section 5.1 says why. Their zeros carry an upper bound rather than a point: 0 of 549 is a recall of 0.0% (0.0–0.7).

Neither combination reaches its own best component at any budget. The corrected minimum reaches 4, 47 and 161 against the novelty detector's 11, 60 and 201; the composite reaches 0, 6 and 113. The composite's zero at 10 and 100 alerts a day is not a calibration artefact that calibration removes — those figures are with conformal calibration applied, and without it the composite reaches 0 at 100 a day rather than 6. Section 5.4 diagnoses both failures.

The same measurement on a corpus differing in background population (holdout-r7-fixed, 262 labelled among 1,427,225 scored) gives the novelty detector 2, 8, 15 and 21 at 10, 25, 50 and 100 alerts a day, and the composite 0 at every budget. Because labelled accounts are exempt from sampling, that corpus shares its

labelled events with this one; it is a check on sensitivity to background, not an independent replication.

5.3 Detection by attack mechanism

The planted corpus separates "this test cannot express this mechanism" from "this budget cannot afford it".

lanl-inj-b1000-union-d7-14-002 : 856 planted events across six mechanisms plus the 549 real labelled events. Attribution is by victim account, which the design makes unambiguous. Planted and real ground truth are reported side by side and never summed.

At 10 alerts a day.

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	ALERTS
<i>per-entity detector</i>								
novelty	0	0	0	0	0	0	11	70
noveltyrate	0	0	0	0	0	0	0	70
pairing	0	0	0	0	0	0	4	70
timing	0	0	0	0	0	0	0	70
volume	0	0	0	0	0	0	0	70
<i>population detector</i>								
marginal	0	0	0	0	0	0	0	70
<i>combination</i>								
composite (Fisher + Brown)	0	0	0	0	0	0	0	70
corrected minimum (Šidák)	0	0	0	0	0	0	4	70
union, per-entity arms (equal cost)	0	0	0	0	0	0	2	70
union, per-entity arms (equal depth)	0	0	0	0	0	0	11	289 (×4.1)
union, all arms (equal cost)	0	0	0	0	0	0	1	70
union, all arms (equal depth)	0	0	0	0	0	0	11	357 (×5.1)

At 100 alerts a day.

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	ALERTS
<i>per-entity detector</i>								
novelty	0	0	0	0	0	0	60	700
noveltyrate	0	0	0	0	0	0	21	700
pairing	0	0	0	0	0	0	59	700
timing	0	0	0	0	0	0	1	700
volume	0	0	0	0	0	0	0	700
<i>population detector</i>								
marginal	0	0	0	0	0	76	0	700
<i>combination</i>								
composite (Fisher + Brown)	0	0	0	0	0	24	0	700
corrected minimum (Šidák)	0	0	0	0	0	0	47	700
union, per-entity arms (equal cost)	0	0	0	0	0	0	24	700
union, per-entity arms (equal depth)	0	0	0	0	0	0	75	2734 (×3.9)
union, all arms (equal cost)	0	0	0	0	0	0	20	700
union, all arms (equal depth)	0	0	0	0	0	76	75	3409 (×4.9)

At 1000 alerts a day.

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	ALERTS
<i>per-entity detector</i>								
novelty	80	15	0	0	0	30	178	7000
noveltyrate	117	26	0	4	0	64	173	7000
pairing	0	0	0	0	0	12	130	7000
timing	0	0	2	0	0	4	6	7000
volume	0	0	0	0	0	0	0	7000
<i>population detector</i>								
marginal	0	0	0	0	0	120/120	0	7000
<i>combination</i>								
composite (Fisher + Brown)	0	4	0	0	0	116	108	7000
corrected minimum (Šidák)	40	10	0	0	0	30	155	7000
union, per-entity arms (equal cost)	2	0	0	0	0	15	101	7000
union, per-entity arms (equal depth)	117	26	2	4	0	64	264	25917 (×3.7)
union, all arms (equal cost)	0	0	0	0	0	120/120	94	7000
union, all arms (equal depth)	117	26	2	4	0	120/120	264	31601 (×4.5)

Planted: spray 320, lateral 40, off-hrs 64, priv-esc 24, low+slow 288, takeover 120, real 549.

Read a per-mechanism count as a coarse rate. Each mechanism has eight victims and a deterministic choice of planted values, so the events of one mechanism are not independent draws and the effective sample size is nearer eight than the event count. "120 of 120" is eight victims of eight.

The budget binds harder than the method. At 10 alerts a day no arm reaches any planted mechanism at all; the only detections anywhere are 11 real-campaign events to the novelty detector and 4 to the pairing detector. At 100 a day exactly one mechanism is reached. At 1000 a day five of six are. For four of the six mechanisms, therefore, the sentence "this framework does not detect it" is false at some budget and true at another, and only the budget changed.

No single method is best at more than one thing. At the widest budget the marginal takes every planted takeover and nothing else; the novelty-rate detector takes credential spray, lateral movement and privilege escalation; the novelty detector takes the real campaign. A reader looking for one row to deploy will not find one.

Low-and-slow is reached by no arm at any budget: 0 of 288, or 0 of 8 victims. It is the mechanism the volume predictive's over-dispersion is built to tolerate, so this is a confirmed prediction rather than an unexplained gap, and section 5.1 shows the volume-burst property is not enriched in any case.

The population marginal detects every planted takeover, and the reason is not the one the design intended to exclude. The corpus plants the most population-common value the victim has never used, precisely so that population rarity is held out; so the marginal's 120 of 120 requires an explanation, and the measurement supplies it. Median p-values for the marginal are 0.59 on credential spray and lateral movement, which substitute the destination computer, and 0.17 on privilege escalation, which substitutes the authentication type; on takeover, which substitutes destination, authentication type and logon type at once, the median is 3.8×10^{-5} .

The pattern follows the cardinality of the substituted field. The destination computer takes 3,535 distinct values in this corpus, so a common value the victim has not used is genuinely common and the marginal is unmoved. Authentication type takes 14 and logon type 10, with steep distributions — Kerberos, NTLM and Negotiate account for 99.6% of resolved authentication types — so an account that already uses the common values can only be given one from the tail. Holding population rarity out succeeds where the vocabulary is large and cannot where it is small, and the takeover row is where that shows. It is a limitation of the planted corpus, stated here because the alternative is to read the row as evidence for a mechanism the design was built to exclude.

5.4 Combination and budget allocation

Section 5.2 established that no rule tested reaches its best component. The two rules fail for different reasons and the union isolates them.

Fisher's sum averages an informative test with uninformative ones. Labelled events sit at the 0.07th percentile of the novelty detector's own distribution and between the 18th and 36th of every other detector's. Summing $-2 \ln P$ over six tests dilutes one signal with five non-signals. Fisher's method is powerful against diffuse alternatives and the minimum against sparse ones; this alternative is sparse.

The corrected minimum compares p-values across tests that share no scale. Under it the novelty detector supplies 5,879 of the 7,000 retained alerts, 84%. Four other detectors divide the remaining 16% — pairing 390, novelty rate 292, timing 225, marginal 214 — and two, volume and co-occurrence, never supply the minimum at all. A detector's p-value is a statement under its own null, so the arm whose null produces numerically smaller values takes the queue whatever the others found.

The union removes that scale, and the result separates two hypotheses that had been running together.

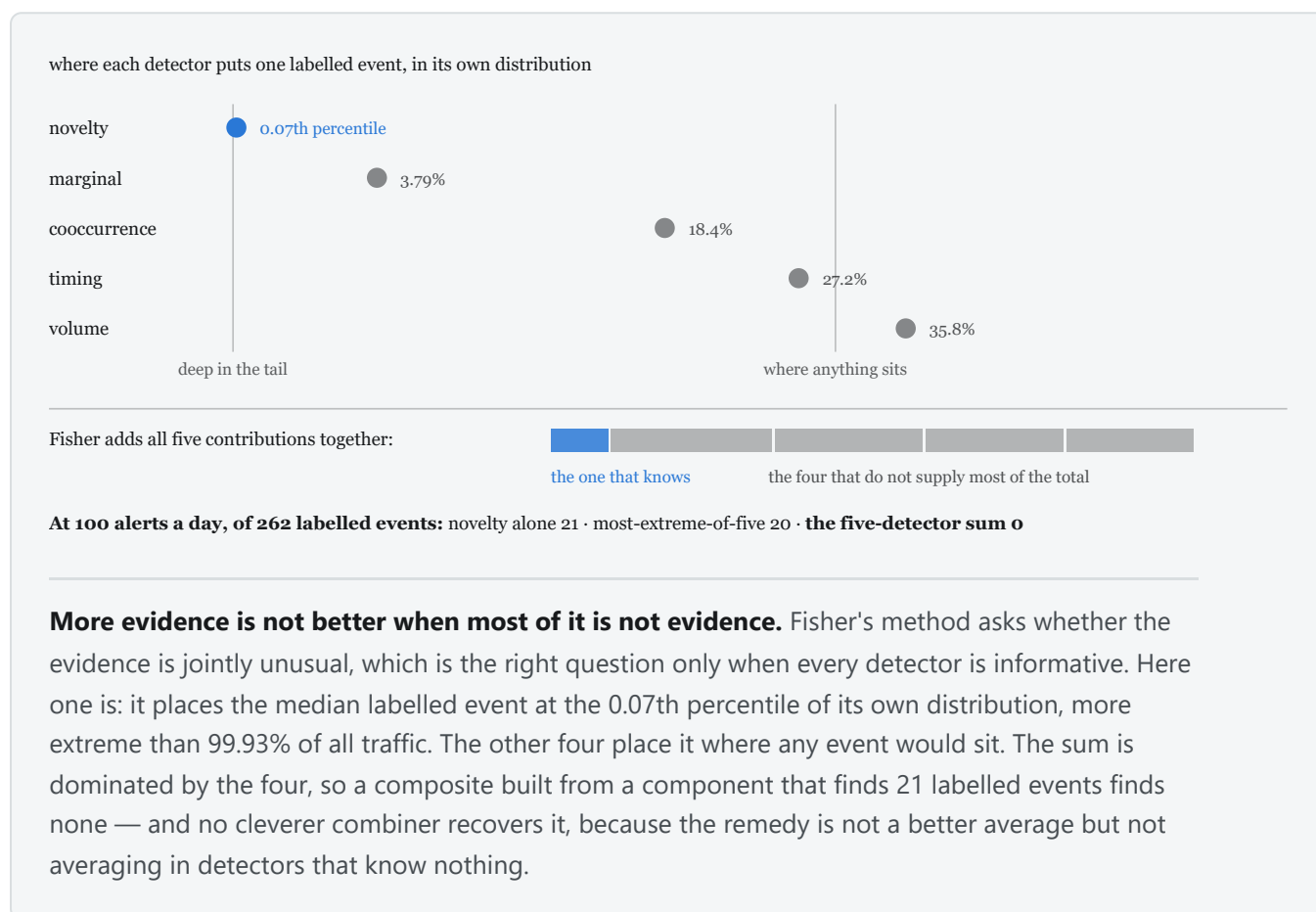
RULE	10/DAY	100/DAY	1000/DAY	ALERTS AT 1000/DAY
best single arm	11	60	201	7,000
union, per-entity arms, equal cost	2	27	106	7,000
union, all arms, equal cost	2	21	96	7,000
union, per-entity arms, equal depth	11	74	278	25,930 ($\times 3.7$)
union, all arms, equal depth	11	74	278	32,134 ($\times 4.5$)

At equal cost the union is strictly dominated at every budget — fewer labelled events and more false alarms than using the best arm alone. The intervals do not overlap: at 1000 a day recall is 17.5% (14.5–20.9) against 36.6% (32.7–40.7). No exchange rate rescues a dominated option.

At equal depth it finds what no single arm finds: 278 against 201 at 1000 a day, recall 50.6% (46.5–54.8) against 36.6% (32.7–40.7), which is a real and separated difference. It spends 3.7 times the alerts to get it.

So the scale mismatch was not the binding defect. Removing it made the marginal's signal reachable, and at equal cost the result got *worse*: the novelty detector holding 84% of the minimum's queue was closer to correct than crowding-out suggested, because it is the better arm. What the union changes is the accounting, not the ranking, and the diagnosis it leaves is this: at a fixed budget, adding an arm divides the queue rather than extending it. Rank fusion takes rank 1 from every arm, then rank 2, so with six arms each reads about a sixth of the depth it had alone, and the novelty detector's 201 detections are spread through the full ranking rather than packed into the top sixth. Complementarity is also rarer than the equal allocation assumes: on the real campaign only two of the 96 detections at equal cost are found by exactly one arm.

The defect is therefore allocation. No rule above divides a budget in proportion to what each arm has demonstrably earned, and section 5.5 measures a rule that does.



5.5 Allocation by demonstrated quality

The allocation result is pending: the two replays it depends on are still running.

5.6 Truncating where the objective peaks

At the exchange rate $v/c = 10$ stated in section 4, and on the corrected-minimum arm:

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	30	4	5.7% → 13.3%	40 (57%)	0
100/day	700	47	221	47	6.7% → 21.3%	479 (68%)	0
1000/day	7,000	161	315	74	2.3% → 23.5%	6,685 (95%)	87

At 10 and 100 alerts a day the truncation is free: 57% and 68% of the queue goes for no loss of detection. At 1000 it becomes a decision — the objective discards 6,685 alerts and 87 true positives with them, because at this rate those 87 do not pay for 6,685 wasted investigations — and precision rises tenfold. For the composite the optimum is to emit nothing at any budget, including the budget at which it finds 113 true positives, which do not pay for 6,887 false ones at $v/c = 10$. An objective declining to deploy a detector is a usable answer.

This is an oracle bound: the optimum is located using the labels, so it measures the headroom a cutoff has rather than being a deployable rule. Section 6 says what a deployable version needs.

Reporting at a nominal false discovery rate instead is not available on this corpus. Applying Benjamini–Hochberg [8] per day to the composite at $q = 0.05$ yields 5,352 discoveries of which 113 are labelled, a realised FDR of 0.979 (0.975–0.982), with five of seven days saturated; Benjamini–Yekutieli [9] under dependence gives 0.978 at $q = 0.001$. The nominal level has no purchase because the p-values it is applied to are not calibrated, and that is a property of the composite rather than of the procedures.

5.7 Population-scope baselines

Six population-scope reference implementations spanning four inductive biases were run: isolation forest [11] and extended isolation forest [12] from scikit-learn [16], half-space trees [13], local outlier factor [14], one-class SVM [15] and PCA reconstruction error. The one-class SVM is a Nyström kernel map with a stochastic-gradient one-class objective rather than the exact kernel machine, which is $O(n^2)$ in the fit set and cannot be run at this row count; it is a deviation from the textbook formulation and is recorded as one. A per-entity reference, an uncalibrated EWMA z-score, was also run.

METHOD	SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL	ALERTS
<i>baseline (per-entity)</i>								
entity_ewma	0	0	0	0	0	1	0	--
<i>baseline (population)</i>								
eif	0	0	0	0	0	0	0	--
hst	0	0	0	0	0	0	0	--
iforest	0	0	0	0	0	0	0	--
lof	0	0	0	0	12	0	0	--
ocsvm	0	0	0	0	0	33	0	--
pca	0	0	0	0	0	0	0	--

On the matched comparison (`baselines-holdout-r7-d7-9` , the same 262 labelled events section 5.2 reproduces on) all six population models detect **0 at every budget**, which section 5.1's census explains: not one labelled event of the real campaign holds a population-rare value.

On the planted corpus two of them are not zero, and the exception is the interesting one. One-class SVM detects 33 of 120 planted takeovers and local outlier factor 12 of 288 low-and-slow events — the one mechanism no arm of this framework reaches at any budget. A sustained small departure is what the volume predictive's over-dispersion is built to tolerate and what a density estimate has no such tolerance for. That is a capability this framework does not have, and it is why sections 1.3 and 6 describe the two scopes as complementary rather than ordered.

Both baseline figures come from an easier problem, in one way that dominates: the models read a 1-in-100 event sample of 45,071 rows rather than 4.49 million events. That raises the labelled share from 0.031% to 3.1%, and it raises the share of the corpus a fixed budget covers by the same factor of about 100. Given a hundredfold easier problem they reached 33 and 12.

The per-entity reference cannot be read at all from this run, and we decline to read it. Sampling uniformly over events decimates every entity's history at the same rate, so an EWMA over an entity's own past is estimated from a hundredth of that past; the export records `entity_history_intact: false` . Its single detection is

neither evidence for nor against the per-entity framing, and a matched entity-sampled export is needed before it means anything.

6. Discussion

6.1 What the evidence supports, and what it does not

Conditioning each null on the entity that produced the event is supported on this campaign, and the support is specific: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, and the property a population-rarity test expresses contains none of them. The direction of that comparison is what the evidence establishes. It is narrower than "per-entity conditioning beats population conditioning", because on planted attacks the population test detects a mechanism no entity-scope test here reaches, and a population density estimate reaches a second one.

Combining evidence across the tests is not supported. Three rules were measured and none exceeds its best component at equal cost at any budget, with non-overlapping intervals at the widest budget. The union at equal depth does exceed it, and costs 3.7 times the alerts to do so; whether that trade is worth taking is what section 4's objective decides and depends on an exchange rate an operator must supply.

6.2 Threats to validity

The novelty p-value is confounded with history length. For a first-ever value the estimate reduces to the reserved mass $a/(n + a(K+1))$, approximately $1/n$. Across 32 planted victims spanning 263 to 20,666 events of history, the product of the p-value and the history length has median 1.15 and lies in $[0.50, 7.22]$: among novel events the ranking is close to sorting accounts by event count. Clearing the detector's realised cut on this corpus requires of the order of 10^5 events of history, and the busiest planted victim had 20,666, so **no attack on an ordinary account could win an alert slot regardless of what it did**. This is a covariate problem — history length is informative about the p-value's scale while being no part of the question — and it is the single largest methodological limitation here. It is also not straightforwardly fixable: the one principled correction tried, reserving unseen mass by Good–Turing rather than by a fixed concentration, *lost* detections, because large histories carry many singletons and the correction therefore judges a first-ever value unremarkable for exactly the accounts the working estimator ranks highest. The working configuration works for a reason the model does not state, and neutralising the covariate risks destroying the accidental correlation the result rests on.

A sustained intrusion enlarges its own reference set. State is committed after scoring, so an event is judged against a history that does not yet include it — but the next event of the same campaign is judged against a history that does. Over a campaign persisting for days on one account, the reference distribution drifts toward the attacker's behaviour. This is an untested alternative explanation for two of the paper's null results, the low-and-slow zero in particular, and it cannot be separated from the stated mechanism without a run that freezes per-entity state across the campaign window.

Effective sample size is far below nominal, so every interval here is optimistic. The 549 labelled events fall on 104 accounts, 93.6% of label rows share one source computer, and two of seven days carry most of them; the unit of independence is nearer the account or the campaign-day than the event. On the planted corpus each mechanism has eight victims and a deterministic choice of values. The Wilson intervals treat alerts as independent draws and therefore understate uncertainty; they are reported because a count with no interval understates it further.

Labels are a partial record, so the figures are bounded in known directions. Malicious activity the red team did not record counts against precision, so every precision figure is a lower bound; and the recall denominator is what was written down. Separately, failed authentications appear in this corpus only for accounts that

succeeded somewhere in it, so the failure population is conditioned on eventual success — a property of the archive, not of a live stream, and one the detectors score.

Several quantities are chosen on the outcome. "The best single arm" is identified per corpus after seeing labels; the exchange rates at which the equal-depth union becomes preferable are computed from the same labels; the truncation optimum in section 5.6 is located using them and is stated as an oracle bound. Across the study, seven detectors, four combination rules, two costings, three budgets, two label sets and two corpora were evaluated with maxima reported, and no multiplicity adjustment is applied to that outer loop. The burn-in split is the one thing fixed in advance, and it is recorded by the commit that fixed it. A held-out corpus for the selected configurations is the correct remedy and has not been run.

Nothing here is measured at full population. Every figure is from an entity subset, where a fixed alerts-per-day budget is a far easier target than on 42.2 million events. One full-population run exists; it scored 42,218,530 events with four of the seven detectors and reports its composite detecting nothing at any budget, so the per-entity arms have never been measured at full scale. A detection rate measured on a subset is not comparable to one measured on the whole.

The negative variance estimate is a finding about the composite, not a nuisance. With six detectors the burn-in covariance implies $\text{Var}[X^2] = -27.5$. Brown's correction absorbs dependence between test statistics; a variance no joint distribution can produce says the estimate is measuring the marginals' misspecification rather than the detectors' dependence. Two of the nulls are known not to be calibrated, which is consistent with that reading. It also means the composite figures throughout are plain Fisher, and that a corrected composite on this corpus awaits calibrated marginals rather than a better covariance estimator.

Aggregating to the entity-day raises apparent recall, and the confound accounts for most of it. An analyst triages accounts rather than log lines, and the same evidence aggregated to (entity, day) reaches 65 of 108 labelled entity-days at 100 alerts a day against 47 of 549 labelled events at the same budget. But Fisher's statistic at entity scope grows with the event count, so the ranking sorts by activity as much as by anomaly; replacing it with the count-normalised standardised form takes 65 down to 14. Most of the apparent gain is the confound. Reporting the aggregate without that correction would be the most flattering presentation available in this paper, which is why it is here rather than in section 5.

6.3 What a deployable version needs

Two gaps separate what is measured here from something that can be run.

The first is a calibrated per-alert probability. Both the allocation rule of section 5.5 and the truncation of section 5.6 need to compare alerts on one scale; the latter currently uses labels to do so and is therefore a bound rather than a rule.

The second is that a fixed budget is a batch construction. Selecting the top B of a day requires the whole day, and an operator at 14:00 does not know what arrives by 23:59; the same objection applies to a per-day Benjamini–Hochberg step-up, whose threshold depends on the number of tests. Section 4's objective does not have this defect — it compares one alert against a stated exchange rate and needs no day context — which is why every quantity in section 5.5 is computed from an alert and from state frozen before the scoring window began. Reporting at matched budgets is how this paper charges methods a comparable cost, not a claim about how a threshold should be set in service.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM Conference on Computer and Communications Security, 1999.
2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events Data Set*. Los Alamos National Laboratory, 2015. CCo 1.0.

3. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
4. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
5. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. Journal of the American Statistical Association 62(318), 1967.
6. Vovk, V., Gammerman, A. and Shafer, G. *Algorithmic Learning in a Random World*. Springer, 2005.
7. Wilson, E. B. *Probable inference, the law of succession, and statistical inference*. Journal of the American Statistical Association 22(158), 1927.
8. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate: a practical and powerful approach to multiple testing*. Journal of the Royal Statistical Society B 57(1), 1995.
9. Benjamini, Y. and Yekutieli, D. *The control of the false discovery rate in multiple testing under dependency*. Annals of Statistics 29(4), 2001.
10. Chernoff, H. *On the distribution of the likelihood ratio*. Annals of Mathematical Statistics 25(3), 1954.
11. Liu, F. T., Ting, K. M. and Zhou, Z.-H. *Isolation Forest*. IEEE International Conference on Data Mining, 2008.
12. Hariri, S., Carrasco Kind, M. and Brunner, R. J. *Extended Isolation Forest*. IEEE Transactions on Knowledge and Data Engineering 33(4), 2021.
13. Tan, S. C., Ting, K. M. and Liu, T. F. *Fast anomaly detection for streaming data*. International Joint Conference on Artificial Intelligence, 2011.
14. Breunig, M. M., Kriegel, H.-P., Ng, R. T. and Sander, J. *LOF: identifying density-based local outliers*. ACM SIGMOD, 2000.
15. Schölkopf, B., Platt, J. C., Shawe-Taylor, J., Smola, A. J. and Williamson, R. C. *Estimating the support of a high-dimensional distribution*. Neural Computation 13(7), 2001.
16. Pedregosa, F. et al. *Scikit-learn: machine learning in Python*. Journal of Machine Learning Research 12, 2011.

Data and code availability

Every number in this paper is read from a machine-generated result file committed alongside the source, each carrying its run identifier, corpus checksums, row counts, seeds and parameters. No figure is a plot of data: each is a diagram of a mechanism, so no figure can disagree with a result. The corpus is third-party and is not redistributed; its provenance and licence are recorded with the code.

Generated by `cmd/thesis` from `docs/PAPER.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.